

Meterpreter vs Reverse Shell — Decision Guide

وش الفرق؟ هل LPORT 443 يحول الجلسة؟ متى reverse_tcp/https وكيف تدير Sessions بدون لخبطة.

Abdullah Nasser Almsan – Personal Pentest Reference

ملاحظة استخدام: هذا المرجع يشرح الاختيار وإدارة جلسات مختبرات eJPT. لإنشاء payloads ارجع إلى ملف MSFvenom السابق بدل تكرار أوامر كثيرة هنا.

SESSION

إدارة

LPORT

البورت

LHOST

عنوانك

PAYLOAD

نوع الجلسة

الفهرس

- أهم تصحيح: LPORT 443 لا يعني Meterpreter
- وش معنى LHOST و LPORT؟
- هل 443 "أفضل"؟
- reverse_tcp vs reverse_http vs reverse_https
- Meterpreter: أوامر توفر وقت
- عندي Shell عادية - هل أقدر أرقّيها؟
- Decision Guide
- أكثر أسباب عدم رجوع Session

1. أهم تصحيح: LPORT 443 لا يعني Meterpreter

نوع الـ payload هو الذي يحدد نوع الجلسة؛ البورت مجرد مكان اتصال.

النقل	النتاج	مثال Payload
TCP عكسي	Meterpreter	windows/x64/meterpreter/reverse_tcp
HTTPS عكسي	Meterpreter	windows/x64/meterpreter/reverse_https
TCP عكسي	Shell عادية	windows/x64/shell/reverse_tcp

الخلاصة: LPORT=443 لا يحوّل shell/reverse_tcp إلى Meterpreter. لو تبي Meterpreter لازم يكون اسم الـ payload نفسه Meterpreter.

2. وش معنى LHOST و LPORT؟

لا تحفظ الأرقام؛ افهم الاتجاه.

الخيار	المعنى	ملاحظة
LHOST	عنوان جهازك الذي يستطيع الهدف الوصول له	في لابات VPN غالبًا عنوان tun0 المناسب

الخيار	المعنى	ملاحظة
LPORT	البورت الذي يستقبل عليه الـ handler/listener	4444 أو 443 أو غيره حسب اللاب
RHOST/RHOSTS	الهدف أو الأهداف	يظهر في كثير من modules وليس كل payloads

اعرف عناوين Kali KALI TERMINAL

ip addr

إذا اخترت LHOST غير قابل للوصول من الهدف، لن ترجع الجلسة حتى لو كان كل شيء آخر صحيحًا.

3. هل 443 "أفضل"؟

أحيانًا يفيد، لكنه ليس زر سحري.

النقطة	الشرح	النتيجة
ميزة محتملة	الشبكات كثيرًا ما تسمح outbound HTTPS/443	قد يزيد فرصة مرور الاتصال في بعض المختبرات
ليس HTTPS تلقائيًا	reverse_tcp على 443 يظل TCP payload	رقم البورت لا يغيّر البروتوكول
HTTPS فعلي	استخدم payload من نوع reverse_https	نوع الـ payload يحدد ذلك
Kali/Linux	الاستماع على بورت أقل من 1024 قد يحتاج صلاحية	قد تحتاج root/capability حسب الأداة

لا تستخدم 443 أو أي payload للالتفاف على ضوابط شبكة لا تملك تصريحًا لاختبارها. الكلام هنا خاص بالمختبرات المصرح بها.

4. reverse_tcp vs reverse_http vs reverse_https

اختيار النقل يعتمد على بيئة اللاب.

النوع	الفكرة	متى أفكر فيه؟
reverse_tcp	بسيط ومباشر	مختبرات داخلية واتصال مباشر
reverse_http	HTTP	عندما السيناريو مصمم لحركة HTTP
reverse_https	HTTPS	عندما السيناريو/المختبر يحتاج HTTPS أو proxy-friendly transport

لا تغيّر transport لمجرد أنه "أقوى". ابدأ بما يطلبه اللاب وبأبسط اتصال يعمل.

5. Meterpreter: أوامر توفر وقت

مرجع سريع بعد حصولك على Session.

```
getuid
sysinfo
pwd
ls
cat [FILE]
ipconfig
route
ps
```

METERPRETER ادخل Shell النظام

```
shell
```

METERPRETER ارجع Metasploit بدون قتل الجلسة

```
background
```

MSFCONSOLE عرض الجلسات

```
sessions
```

MSFCONSOLE ارجع لجلسة

```
sessions -i 1
```

METERPRETER رفع / تنزيل ملفات مختبرية

```
upload [LOCAL_FILE] [REMOTE_PATH]
download [REMOTE_FILE] [LOCAL_PATH]
```

6. عندي Shell عادية - هل أقدر أرقبها؟

Metasploit يستطيع المحاولة في بعض الحالات.

MSFCONSOLE اعرض الجلسات

```
sessions
```

MSFCONSOLE محاولة Upgrade

```
sessions -u 1
```

استبدل 1 برقم session shell. النجاح يعتمد على النظام والarchitecture والاتصال والpayload المتاح.

Decision Guide .7

اختيار سريع أثناء الالاب.

المبدأ	الاختيار	الحالة
حسّنها بـ PTY إذا Linux	Shell عادية تكفي	أحتاج أوامر قليلة فقط
استخدم Meterpreter payload مناسب للسيناريو	Meterpreter مفيد	أحتاج upload/download و sysinfo/session management
حسب الـ handler والسيناريو	فكر reverse_http/https	الاتصال يرجع عبر HTTP/HTTPS في الالاب
كمل إذا تحقق الهدف	لا تغيّرها فقط لأن Meterpreter "أجمل"	عندي shell شغالة

8. أكثر أسباب عدم رجوع Session

راجعها قبل تبديل عشر أشياء.

الحل الأول	العلامة	العطل
راجع tun0/eth0 ومسار الهدف	عنوان غير قابل للوصول	LHOST خطأ
Kali على ss -lntp	Listener لا يستطيع bind	LPORT مشغول
شغل بالأذونات المناسبة في المختبر أو اختر بورتًا آخر	bind permission denied	بورت 443 بدون صلاحية
راجع sysinfo/المعمارية	x86/x64 أو OS مختلف	Payload/Architecture غير مناسب
استخدم فقط خيارات السيناريو المصرح بها	الاتصال لا يخرج	Firewall/Egress

مرجع مراجعة سريع للتعلّم والاختبارات المصرّح بها فقط.

Refs: Rapid7 Metasploit Documentation · Metasploit Framework payload/session documentation